Western Governor's University

Legal Issues in Information Security

C841

Sara Goodie

IHP4 Task 1: Legal Analysis

IHP4 Task 1: Legal Analysis

A1. CFAA and ECPA

The Computer Fraud and Abuse Act (CFAA) is a United States law that focuses on computer related crimes that includes unauthorized access to computer systems/data and or other forms of computer fraud. In the TechFite case study, there was one example of the CFAA being violated. This example involves Carl Jaspers, who was the head of TechFite's application division, which allowed the Business Intelligence unit to access documents outside of their own division. Jaspers executed this by giving and escalating privileges to dummy user accounts. Emails associated with these accounts were given to parties who are not clients of TechFite, and they referred to intelligence-gathering activities against various companies, including references to "dumpster diving" and "trash surveillance". These user accounts might have been used for unauthorized access to various companies' networks and for activities. This is a clear violation of the CFAA because it proves that Jaspers and the Business Intelligence unit intentionally gave themselves unauthorized access to secured computer systems.

The Electronic Communications Privacy Act (ECPA) is a law that protects data against interceptions whether it's telephone conversations or digital communications, that is in transit. In the TechFite case study, there was one example of the ECPA being violated. Which is the companies' use of Metasploit. Metasploit is a tool that allows for system penetration as well as scanning IP traffic. This tool was used to intercept communications through multiple IP addresses for quite a few companies. All of this was evidently found on the company's hard drives. The BI Unit intercepted, accessed, and monitored electronic communications without proper authorization which violates the ECPA.

A2. Three Laws

TechFite also broke The Electronic Communications Privacy Act (ECPA). TechFite violated this law, specifically the Business Intelligence unit, by using the Metasploit tool without care. This Metasploit tool is a system penetration testing tool that helps identify and exploit vulnerabilities in computer systems, as well as to assess various other networks. The Business Intelligence unit used this tool to perform unauthorized surveillance, interception of electronic communications, and access to other departments' systems without proper authorization, which violates the ECPA. Legal action should happen to those who participated in this crime and be carried out by people who had their data intercepted without their consent.

TechFite broke the Computer Fraud and Abuse Act (CFAA). TechFite violated the law because they didn't have safeguards like the principle of least privilege and clear roles in place. This made it easy for Carl Jasper to ignore the CFAA by increasing access rights for the Business Intelligence unit through dummy accounts using names of former TechFite employees. These actions allowed the Business Intelligence unit to get into systems and files they shouldn't have, like legal, HR, and financial records. Legal action is needed because TechFite's Business Intelligence unit went into records and documents they weren't supposed to access, going beyond of what they were allowed to view.

Thirdly, TechFite violated the Sarbanes-Oxley Act of 2002 (SOX) as well. TechFite broke this law because of fraudulent financial activities. The investigation showed the existence of three companies that were referred to as “shell” companies. They were all registered under the name of "Yu Lee" in Nevada. These companies were used to dishonestly boost TechFite's financial records through hidden transactions involving a financial institution called "Freeworkers Bank" in Scranton, PA. TechFite is a publicly traded company on NASDAQ, and these fraudulent actions, which were supposed to artificially improve their financial records, mislead and deceived potential investors. This deception and

manipulation of financial data should go through legal action under the Sarbanes-Oxley Act, which was established to ensure transparency and accuracy in financial reporting by publicly traded companies.

A3. Duty of Due Care

In the Applications Division's Business Intelligence Unit, they didn't do a good job of keeping sensitive client data separated. Normally, you should only give people access to what they need, and you should make sure one client's data doesn't mix with another's. But in the BI Unit, everyone had too much access, and there was no clear plan to keep client data apart. This lack of proper security in the Business Intelligence Unit put client information at risk. It means that someone dealing with one client's data could easily see another client's info. This could lead to information leaks, unauthorized access, and data breaches. The Business Intelligence Unit's lack of strict oversight and failure to follow essential security rules put client data at risk and made people doubt the division's commitment to protecting sensitive information.

Another example of when duty of care was lacking is TechFite's vague and incomplete reports by IT Security Analyst Nadia Johnson. She was responsible for summarizing the division's activities, including any security concerns. However, when it came to the internal reports, her documentation was far from enough regarding the Business Intelligence unit. She only provided general summaries and claimed there were no problems, even though evidence suggested otherwise. There was no accurate checking of data loss prevention for sensitive documents, privilege escalation, or surveillance of internal network traffic. This demonstrated a significant lack of care within TechFite.

A4. SOX

TechFite, as a publicly traded company on NASDAQ, is subject to the rules of the Sarbanes-Oxley Act (SOX). SOX guarantees honesty in financial reporting for such companies. The issue here is with

TechFite's Applications Division, which has been in the news for questionable practices, including potential data breaches and misusing information. A specific SOX violation we've observed is that TechFite isn't protecting sensitive client information. SOX expects companies to have strong internal controls to safeguard such data and prevent unauthorized access. TechFite's did not properly separate client data, lack oversight on internal activities, and allowing unauthorized access to other parts of the company. These problems not only put data security at risk but also raise concerns about the accuracy of financial reporting, which is a big deal under SOX.

B1/B1a. Criminal Evidence, Activity, Actors and Victims

One specific activity that I observed in this case study is the unauthorized access to sensitive client information and later data breach within TechFite's Applications Division. The primary actors involved are the individuals within the TechFite's Business Intelligence Unit, specifically Jack Hudson, Megan Rogers, and Sarah Miller. The victims are TechFite's clients which are Orange Leaf Software LLC, and Union City Electronic Ventures. Their confidential data was accessed without authorization.

Another specific activity that I observed in this case study is when Carl Jaspers created two dummy user accounts, that used names of employees that didn't work for the company anymore. He used the accounts to steal confidential and important information. The victims are rival companies and competitors in the internet division. Who all suffered from the theft of their sensitive information due to Carl Jasper's unethical leadership and loose internal controls.

B1b. Cybersecurity Policies & Procedures for Criminal Activity

A cybersecurity policy that could have prevented many of the issues in the Techfite case is the "least privilege" principle. This means giving each user account only the exact permissions they need as per the security and group policy. If this principle had been enforced, it would have stopped the creation of those fake accounts and the manipulation of financial records by Carl Jaspers. Having clear security policies and procedures in place at Techfite could have caught these issues and potentially stopped any harm caused by Jaspers.

Another cybersecurity policy procedure that could have helped prevent criminal activity is implementing an Acceptable Use Policy (AUP). In simple terms, an AUP is like a rulebook that employees need to follow when using TechFite's network, websites, or systems. It sets clear rules for using these resources and, most importantly, employees must sign it to show they understand and agree to follow these rules. If someone breaks the rules, having their signature on the policy makes it clear that they knew what they were supposed to do.

B2/B2a. Evidence of Negligent Activity, Actors and Victims

The first individual/group that acted negligently is The Business Intelligence Unit. Their actions involved deploying the penetration testing tool (Metasploit) and scanning activity into IP addresses of various Internet-based companies, which could lead to network vulnerabilities and unauthorized access to sensitive data within TechFite. These negligent actions could harm the organization's overall cybersecurity and its internal operations. The victim(s) is TechFite’s network and other operations.

The second individual/group that acted negligently is Carl Jaspers, the head of the Application Division. Carl Jaspers made clients like Orange Leaf and Union City Electronic Ventures sign

nondisclosure agreements (NDAs), but he didn't adequately protect their data within the Applications Division. This mistake led to confidential client information being accessed and misused, which harmed TechFite's clients when their valuable data ended up in the hands of rivals. The victim(s) are TechFite's clients which are Orange Lead Software LLC and Union City Electronic Ventures.

B2b. Cybersecurity Policies & procedures for Negligent Activity

To prevent problems like making unauthorized user accounts that stay active even after employees leave, TechFite should have a clear set of rules known as the "Access Control and User Account Management Policy." This would help ensure that only the right people get access to the company's systems and data. The rules include things like having a proper process for creating accounts, checking regularly to see who should have access, and making sure accounts are turned off when people no longer work there. It also involves keeping a close eye on important accounts, using strong passwords, and watching what people do with their accounts.

Another way to prevent the security problems at TechFite, is that they should implement the "Data Separation Policy." This rule would make sure that important information from different clients is kept separate and protected. It means that each client's data will allow only authorized people to open it. This way, data from one client is kept away from data of others, reducing the chances of it getting into the wrong hands. It would have stopped situations where client information was shared incorrectly.

C. Legal Compliance Summary for Management

In summary, TechFite's is non-compliant to all the laws covered within the case study, which includes CFAA, ECPA, and SOX. The organization's failure to implement permission restrictions for employees allowed unauthorized access to sensitive information, which is a violation of CFAA. The BI Unit's unauthorized use of the Metasploit Tool for scanning other companies' activities without their consent demonstrates a breach of ECPA. Furthermore, TechFite's lack of auditing policies led to the creation of three illegitimate companies, illegally boosting the company's performance figures and resulting in non-compliance with SOX.

References

TechFite Case Study –

https://tasks.wgu.edu/student/011162967/course/26160009/task/3346/overview